

Cybersecurity Training Diary

Day 27: Container & Kubernetes Security

1. Topics Covered

✓ Container Threat Model

```
graph TD
    A[Container Threats] --> B[Image Vulnerabilities]
    A --> C[Runtime Breakouts]
    A --> D[Orchestration Misconfigs]
    B --> E[Malicious Packages]
    C --> F[Privilege Escalation]
    D --> G[Exposed Dashboard]
```

✓ Kubernetes Security Controls

Layer	Security Measure	Tools
Build	Image Scanning	Trivy, Clair
Deploy	Pod Security Policies	OPA Gatekeeper
Runtime	Network Segmentation	Calico, Cilium
Monitor	Anomaly Detection	Falco, kube-bench

✓ Critical CVEs

- **CVE-2021-25735**: Kubernetes Node Allocatable Bypass
- **CVE-2022-0811**: cri-o Container Escape
- **CVE-2023-2727**: Kubeflow Privilege Escalation

2. Key Takeaways

- ✓ **Immutable containers** > patching running instances
- ✓ **Least privilege** applies to pods too (non-root, read-only FS)
- ✓ **Kubernetes defaults are insecure** - always harden clusters

3. Practical Exercises

- ♦ **Exercise 1: Scan for Vulnerabilities**

```
trivy image nginx:latest
kube-bench run --targets=master,node
```

- ♦ **Exercise 2: Create Security Context**

```
# pod-security.yaml
apiVersion: v1
kind: Pod
metadata:
  name: secured
spec:
  securityContext:
    runAsNonRoot: true
    seccompProfile:
      type: RuntimeDefault
  containers:
    - name: app
      image: nginx
      securityContext:
        allowPrivilegeEscalation: false
        readOnlyRootFilesystem: true
```

4. Questions for Reflection

- ? Why are container escapes particularly dangerous?
- ? How does service mesh (Istio/Linkerd) improve security?